



❖ ACSC ESSENTIAL EIGHT ❖

8 Essential Eight

Mitigation Strategies

Australian Cyber Security Centre (ACSC)

[CYBER SECURITY NOTES]

*"Eight strategies to prevent the most targeted
cyber security incidents across organisations.
— ACSC Essential Eight Framework"*

MATURITY LEVELS

ML 0 — Exposed

ML 1 — Basic

ML 2 — Managed

ML 3 — Optimised

WHAT'S INSIDE

Patch Applications

Patch OS

MFA

Admin Privileges

App Control

Office Macros

App Hardening

Regular Backups

YG

Yadav Ghorasainee

linkedin.com/in/yadav-ghorasainee
yadavgcybernet.github.io/sec/

What is the Essential Eight?

ACSC Essential Eight Overview

- Published by the Australian Cyber Security Centre (ACSC)
- A set of 8 prioritised strategies to protect organisations
- Designed to prevent cyberattacks and limit data breaches

Key Objectives:

- Prevent malware from being delivered and executed on systems
- Limit the extent and damage of a cyber security incident
- Enable rapid data recovery and restore system availability

Key Features:

- Risk-based, maturity-driven and easy to scale across sectors
- Applicable to all sectors: small business to large enterprise
- Fully aligned with Australian Government cyber security policy

EXAMPLE:

A medium-sized law firm adopts the Essential Eight to protect client confidentiality. They start at ML 1 and roadmap to ML 3 over 12 months — reducing their breach risk by over 85%.

Maturity Levels

Four Maturity Levels (ML 0 → ML 3)

- **ML 0 → No controls implemented — fully exposed to risk**

→ Organisation has not addressed any of the eight strategies

- **ML 1 → Partially aligned — basic controls are in place**

→ Controls exist but are inconsistently applied or incomplete

- **ML 2 → Mostly aligned — risk is significantly reduced**

→ Controls consistently applied with some automation in place

- **ML 3 → Fully aligned — highest level of cyber protection**

→ Controls fully automated, monitored and continuously improved

Recommended Targets:

- All organisations should achieve at least Maturity Level 2
- High-risk and critical infrastructure systems must reach ML 3

EXAMPLE:

Agency needs to manage application patching across 500 systems.

ML 1: Patches manually applied once a month by IT helpdesk.

ML 2: Patches deployed automatically within two weeks of release.

ML 3: Critical patches auto-pushed within 48 hours — every system.

Strategy 1: Patch Applications

Apply Security Patches to All Applications

- Apply patches to ALL applications used across the organisation
- Focus: browsers, PDF readers, email clients, office suites
- Prioritise internet-facing applications before internal ones

Maturity Targets:

- **ML 1** → All patches applied within 1 month of release
- **ML 2** → All patches applied within 2 weeks of release
- **ML 3** → Critical patches deployed within 48 hours

Why It Matters:

- Unpatched applications are the #1 attacker entry point globally
- Patching quickly closes known, actively exploited CVE gaps
- Automated patch management tools remove human error risk entirely

EXAMPLE:

Critical zero-day found in Google Chrome on a Monday morning.
ML 1 org: IT team manually patches devices by end of the month.
ML 3 org: Automated tools push the patch to ALL workstations within 48 hours — risk is fully eliminated before exploitation.

Strategy 2: Patch Operating Systems

Apply OS Security Updates to All Systems

- Apply OS security updates to all workstations and servers
- Replace or retire any end-of-life operating systems promptly
- Use vulnerability scanners to identify all unpatched systems

Maturity Targets:

- ML 1 → OS patches applied within 1 month of release
- ML 2 → OS patches applied within 2 weeks of release
- ML 3 → Critical OS patches deployed within 48 hours

Key Focus Areas:

- Internet-facing and public-facing servers are patched first
- End-of-support OS versions are fully removed from production
- Patch testing in a staging environment before wide deployment

EXAMPLE:

Microsoft releases a critical Windows Server patch — remote code execution vulnerability if left unpatched on any server.

ML 1 org: Server patched manually by IT at end of the month.

ML 3 org: WSUS auto-deploys to all servers within 48 hours.

Strategy 3: Multi-Factor Authentication

Require 2+ Verification Factors for All Access

- Require 2 or more verification factors to access any system
- Applied to: remote access, email, cloud services, admin accounts

The Three Authentication Factors:

- Something you **KNOW** → Password or personal PIN code
- Something you **HAVE** → Hardware token or smart card
- Something you **ARE** → Fingerprint or Face ID biometrics

Maturity Targets:

- **ML 1** → MFA enabled on all internet-facing services
- **ML 2** → MFA required for all privileged and remote access
- **ML 3** → Phishing-resistant MFA enforced for every single user

EXAMPLE:

Sarah logs into the company VPN from home after hours.

Step 1: She enters her username and correct password.

Step 2: Microsoft Authenticator sends a push notification to her phone.

Result: Both factors verified — VPN access granted securely. ✓

Strategy 4: Restrict Admin Privileges

Grant Admin Rights Only to Those Who Need Them

- Grant admin rights ONLY to users who genuinely require them
- Use separate accounts for admin tasks vs everyday activities
- Review, validate and remove unused admin accounts regularly

Key Principles:

- Principle of Least Privilege — minimum access required only
- Admin accounts must NEVER be used for email or web browsing
- Disable or lock all admin accounts when not actively in use

Maturity Targets:

- ML 1 → Admin privileges are validated and fully documented
- ML 2 → Just-in-time access — elevated only when required
- ML 3 → Privileged Access Workstations (PAW) enforced

EXAMPLE:

James is a senior IT admin at a healthcare company.

Daily: james@org.com — standard account for email and Teams only.

Admin: james.admin@org.com — used ONLY for server configuration, requires MFA, all actions fully logged. Auto-locked out of hours.

Strategy 5: Application Control

Only Pre-Approved Applications Can Execute

- Only pre-approved and trusted applications can execute
- Allowlisting model — anything not approved is blocked by default
- Prevents malware, ransomware and rogue executables from running

Technologies Used:

- Windows Defender Application Control (WDAC)
- AppLocker — built into Windows Enterprise editions
- Third-party enterprise allowlisting and control platforms

Maturity Targets:

- **ML 1** → Application control applied on all user workstations
- **ML 2** → Extended to servers and internet-facing systems
- **ML 3** → Allowlist rules validated, logged and regularly reviewed

EXAMPLE:

Attacker sends phishing email with a malicious attachment: invoice.exe

Employee clicks the file and attempts to run the attachment.

Without control: Malware installs silently and begins spreading.

With ML 3: invoice.exe is NOT on the allowlist — blocked instantly. ✓

Strategy 6: Restrict Office Macros

Block Untrusted Macros in Microsoft Office Files

- Block macros inside MS Office files received from the internet
- Only allow macros from trusted, business-approved locations
- All approved macros must be digitally signed by the organisation

Why Macros Are Dangerous:

- Macros are one of the top malware delivery mechanisms today
- Phishing emails attach Word / Excel files with hidden macro code
- One click on 'Enable Macros' can silently compromise the system

Maturity Targets:

- **ML 1** → **Macros disabled in all non-essential scenarios**
- **ML 2** → **Only digitally-signed macros are permitted to execute**
- **ML 3** → **Antivirus actively scans all macros before they run**

EXAMPLE:

Staff member receives email: 'Your invoice is ready — see attached.'
Excel file displays: 'Enable Macros to view content.'
The macro is unsigned and downloaded from an external internet source.
ML 2 policy: Unsigned macro is auto-blocked — no infection occurs. ✓

Strategy 7: User Application Hardening

Securely Configure Browsers and Office Applications

- Securely configure all web browsers and office applications
- Disable dangerous features that are not required by the user
- Block all web content and active scripts from untrusted sources

Key Hardening Controls:

- Disable Adobe Flash and Java browser plugins completely
- Block advertisements and content from all untrusted domains
- Disable OLE packages and auto-run macros in Office documents

Maturity Targets:

- **ML 1** → Browsers and PDF readers hardened via group policy
- **ML 2** → Office suite hardened and internet access isolated
- **ML 3** → Full web content filtering enforced org-wide

EXAMPLE:

User visits a news website that loads a malicious advertisement.
The ad attempts to exploit an Adobe Flash vulnerability in Chrome.
Without hardening: Flash runs the exploit — malware downloads silently.
With ML 2: Flash is disabled via group policy — threat never loads. ✓

Strategy 8: Regular Backups

Back Up All Critical Data, Configs and System Settings

- Back up all critical data, software configs and system settings
- Store backups securely and isolated from the live environment
- Test backup restoration regularly to confirm recovery works fully

The 3-2-1 Backup Rule:

- 3 → Maintain at least 3 separate copies of all important data
- 2 → Store on 2 different media types (e.g. disk + cloud vault)
- 1 → Keep 1 copy completely offsite or in isolated cloud storage

Maturity Targets:

- ML 1 → Backups completed and access is strictly restricted
- ML 2 → Backups are regularly tested for successful restoration
- ML 3 → Backups fully isolated — no connection to live network

EXAMPLE:

Ransomware encrypts ALL company files on a Friday evening.
Without backups: Organisation must pay the ransom or lose data forever.
With ML 3: Clean isolated offline backup from Thursday exists.
IT restores all files within 4 hours — zero ransom paid. ✓

Key Takeaways

Essential Eight Core Flow:



Core Key Principles:

- Risk-based, maturity-driven and continuously improved approach
- All 8 strategies work together — never implement in isolation
- Security controls must always align with real business objectives

All 8 Strategies — Quick Reference:

- 1. Patch Applications 2. Patch Operating Systems
- 3. Multi-Factor Authentication 4. Restrict Admin Privileges
- 5. Application Control 6. Restrict Office Macros

Thanks for Reading!

Save for reference · Share with your network · Apply the Essential Eight!

[linkedin.com/in/yadav-ghorasainee](https://www.linkedin.com/in/yadav-ghorasainee) | yadavgybernet.github.io/sec/